Guide pédagogique des analyses

Comprendre, vérifier et défendre le rapport MEDICA-SERVICES

À lire d'abord. Ce guide explique le raisonnement suivi dans le rapport d'audit et dans la grille Excel. Il ne constitue pas le corrigé officiel du TD. Chaque note et chaque niveau est une interprétation argumentée des pièces, que l'enseignant peut juger autrement. Les passages qui reposent sur une hypothèse ou un choix discutable sont signalés comme tels, afin que tu saches où se situent les marges de discussion à l'oral.

Table des matières

1 Le cadre du travail **3**

1.1 Ce que demande le TD . . . 3

1.2 Le vocabulaire utilisé . . . 3

1.3 Le rôle des pièces P et T . . . 4

1.4 La méthode DCSSI en une page . . . 4

2 G1, définir le périmètre **5**

3 G2, calculer le niveau adéquat **5**

3.1 Chaque note expliquée . . . 5

3.2 Le calcul pas à pas . . . 6

3.3 Pourquoi ce résultat est robuste . . . 6

3.4 L'ajustement . . . 6

4 G3, établir la maturité effective **6**

4.1 La grille des exigences . . . 7

4.2 Chaque niveau expliqué . . . 7

4.3 Revendiqué, démontré, indéterminé . . . 8

5 T1 à T5, l'audit technique **8**

5.1 T1, lire une matrice de flux . . . 8

5.2 T2, calculer la couverture MFA . . . 8

5.3 T3, passer du CVSS au risque . . . 9

5.4 T4, bâtir une chronologie neutre . . . 9

5.5 T5, corréler sans tricher . . . 9

6 G4, risques, budget et feuille de route **9**

6.1 Coter un risque . . . 9

6.2 L'arbitrage budgétaire, étape par étape . . . 10

6.3 Les preuves de clôture 10
6.4 La trajectoire sur douze mois 11

7 La grille Excel, onglet par onglet **11**

8 L'organisation du projet **11**

9 Hypothèses et choix discutables **12**

10 Préparer l'oral **13**

1 Le cadre du travail

1.1 Ce que demande le TD

Le sujet place l'équipe dans la position d'auditeurs mandatés par la direction générale de MEDICA-SERVICES, un hébergeur d'applications pour des établissements de soins. Le travail consiste à confronter ce que l'entreprise dit d'elle-même avec ce que ses documents et ses extraits techniques prouvent réellement. Il se divise en deux moitiés notées chacune sur 10 points. La partie gouvernance (G1 à G4) applique la méthode de maturité SSI publiée en 2007 par la DCSSI, l'ancêtre de l'ANSSI. La partie technique (T1 à T5) analyse les extraits de pare-feu, de comptes, de vulnérabilités, de journaux et de sauvegardes. La dernière question technique, T5, relie les deux mondes en montrant comment un défaut technique traduit une faiblesse de pilotage.

L'idée centrale du TD tient en une phrase. Un auditeur ne note pas ce qu'on lui raconte, il note ce qu'on lui prouve, et il dit clairement ce qu'il ne peut pas conclure. C'est pour cela que le rapport sépare sans cesse le fait observé, la déclaration, l'interprétation et l'information manquante.

1.2 Le vocabulaire utilisé

Terme	Sens dans ce dossier
Fait	Ce qu'une pièce montre effectivement, avec sa date et son périmètre. Exemple, T04 indique 6 comptes MFA sur 10.
Preuve	La référence qui permet à un tiers de retrouver le fait (Pxx ou Txx). Une déclaration est une preuve faible, un extrait technique daté est une preuve plus forte.
Interprétation	La conclusion que l'auditeur tire du fait, limitée à ce que la pièce couvre. Un échantillon de dix comptes ne dit rien des comptes absents de l'export.
Risque	Un événement redouté qui toucherait un actif ou un métier, compte tenu d'une menace, d'une faiblesse et des mesures existantes.
Recommandation	Une action concrète avec un pilote, une échéance et la pièce future qui prouvera qu'elle a été faite.
Niveau adéquat	Le niveau de rigueur que l'organisme devrait viser au regard de ses enjeux. C'est une cible, pas un constat.
Niveau effectif	Le niveau de maturité réellement démontré pour un processus, selon des exigences cumulatives.
Exigences cumulatives	Pour avoir le niveau 2, il faut toutes les exigences du niveau 1 et toutes celles du niveau 2. Une seule exigence manquante suffit à bloquer le niveau.
Processus SSI	Les sept activités que la méthode examine, de la stratégie à l'exploitation des mesures.
CVSS	Score de 0 à 10 qui décrit la gravité technique d'une vulnérabilité dans l'absolu. Il ignore l'exposition réelle et l'importance métier de l'actif.
RTO et RPO	Le RTO est le délai maximal de reprise d'un service (ici 8 h, P01). Le RPO est la quantité maximale de données qu'on accepte de perdre, exprimée en durée. Le dossier ne donne aucun RPO.
MFA	Authentification à plusieurs facteurs, par exemple mot de passe plus code sur téléphone. Elle rend inutile un mot de passe volé seul.
DMZ	Zone tampon entre Internet et le réseau interne, où l'on place les serveurs publiés comme WEB01.
VLAN	Segment logique du réseau. Les règles de pare-feu contrôlent ce qui passe d'un VLAN à l'autre.
Bastion	Serveur par lequel tous les administrateurs doivent passer, ce qui centralise et trace leurs sessions.
SIEM	Outil qui collecte les journaux et lève des alertes. Une alerte n'est utile que si quelqu'un la qualifie.
Signature SMB	Option qui empêche un attaquant de relayer une authentification vers un serveur de fichiers.

Terme	Sens dans ce dossier
PV	Procès-verbal, ici le compte rendu daté d'un test ou d'une revue. C'est la preuve attendue par un auditeur.

1.3 Le rôle des pièces P et T

Les pièces P décrivent l'organisation et servent surtout à la gouvernance. Les pièces T sont des extraits techniques qui servent à l'audit technique et à vérifier les déclarations des pièces P. Le tableau indique où chaque pièce est principalement utilisée.

Pièce	Contenu	Utilisation principale
P01	Identité, 12 clients, RTO de 8 h	Périmètre (G1), Q01 à Q04, critère de reprise en T4
P02	Organigramme, RSSI à mi-temps	Responsabilités (G1), discussion de l'ajustement (G2)
P03	Architecture, MFA à 60 %	Périmètre, Q11, recoupement avec T04
P04	Entretien de la DG sur l'impact	Q01 à Q04, preuve déclarative
P05	Données de patients et de santé	Q03, Q05, Q06, impact des risques
P06	Registre de 10 événements	Q07, Q12, supervision, vraisemblance de l'hameçonnage
P07	Menaces et contrôles contractuels	Q08, Q09, Q11, menace des scénarios
P08	Hétérogénéité et rythme des changements	Q10, Q12, risque R06
P09 à P15	Une pièce par processus DCSSI	Niveaux effectifs (G3)
P16	Montants du plan	Arbitrage budgétaire (G4)
P17	Trois contradictions	Écart entre déclaré et démontré, G3 et T2, T4
T01, T02	Schéma et règles de pare-feu	T1
T03, T04	Comptes privilégiés et MFA	T2
T05, T06	Vulnérabilités et correctifs	T3
T07 à T09	Journaux, alerte, sauvegardes	T4
T10	Options techniques chiffrées	Arbitrage budgétaire (G4)

1.4 La méthode DCSSI en une page

La méthode de 2007 répond à deux questions successives. La première est de savoir quel niveau de rigueur l'organisme devrait viser. On y répond par un autodiagnostic en douze questions notées de 0 à 3, regroupées en quatre familles de trois. Pour chaque famille on garde la note la plus haute, on additionne les quatre maxima et on lit le niveau dans un barème. Une somme de 0 à 2 donne le niveau 1, de 3 à 5 le niveau 2, de 6 à 8 le niveau 3, de 9 à 10 le niveau 4 et de 11 à 12 le niveau 5. L'autorité responsable peut ajuster ce résultat d'un niveau au plus, en le justifiant.

La seconde question est de savoir quel niveau chaque processus atteint réellement. On examine pour cela sept processus, quatre de pilotage (stratégie, risques, règles, supervision) et trois opérationnels (concevoir, réaliser, exploiter les mesures). Chacun reçoit un niveau de 0 à 5 selon des exigences cumulatives. Le niveau 1 demande des actions menées avec des pratiques de base. Le niveau 2 demande en plus que les actions soient planifiées, menées par des personnes compétentes, en partie formalisées, mesurées qualitativement et portées à la connaissance des autorités. Le niveau 3 demande un processus défini, standardisé sur tout l'organisme et soutenu par des ressources. Le niveau 4 ajoute la mesure quantitative et l'amélioration fondée sur ces mesures, et le niveau 5 l'amélioration continue formalisée. Pour progresser, la méthode conseille de commencer par les processus les plus faibles et de monter d'un niveau à la fois.

Piège classique. Le niveau adéquat n'est jamais une note de sécurité. Dire « MEDICA-SERVICES est au niveau 4 » est faux. Il faut dire que sa cible est 4 et que ses processus démontrent 1 ou 2.

2 G1, définir le périmètre

Le périmètre doit être homogène en termes de responsabilité, c'est-à-dire placé sous une même autorité qui répondra à l'autodiagnostic. Nous avons retenu le service d'hébergement et d'exploitation rendu aux clients, sous l'autorité de la DG. Si l'on avait inclus les systèmes des établissements clients, le niveau adéquat aurait reflété des enjeux que MEDICA-SERVICES ne maîtrise pas. La méthode prévient d'ailleurs qu'un périmètre trop vaste fait remonter la cible à celle de sa partie la plus exigeante.

Le tableau du périmètre du rapport reprend les rubriques demandées par le sujet. Les responsabilités viennent de P02 et P09, les clients de P01, les actifs essentiels de P03 et P05, les services supports de P03 et T01, les interconnexions de P03, P07 et T01. Les exclusions sont aussi importantes que les inclusions, car elles montrent que l'on sait ce que l'on n'a pas audité. Les agences de Bordeaux et Montpellier, citées dans P01, n'apparaissent dans aucun schéma technique et sont donc signalées comme non décrites.

Le sujet demande trois informations manquantes et la demande de preuve associée. Nous avons choisi celles qui bloquent le plus nos conclusions. Sans objectifs de reprise par service, on ne peut pas juger si 8 h sont tenables. Sans liste exhaustive des comptes privilégiés, le taux MFA de 60 % ne vaut que pour l'export. Sans suite donnée à l'alerte AL-1048, on ne peut pas qualifier l'événement du 9 octobre. D'autres choix seraient défendables, par exemple les détails de la réplication vers le site de secours ou la liste des partages de fichiers. L'important est d'associer chaque manque à une preuve précise à demander, comme un document, un export ou un entretien contradictoire.

3 G2, calculer le niveau adéquat

3.1 Chaque note expliquée

Pour chaque question, le tableau indique ce que montre la pièce, comment nous l'interprétons, pourquoi nous retenons la note et ce qui pourrait la faire évoluer. Les intitulés des réponses viennent de la méthode officielle. La note 3 correspond toujours au cas le plus grave, comme « vital », « fatal » ou « catastrophique ».

Question	Ce que montre la pièce	Notre interprétation	Pourquoi cette note	Ce qui la ferait évoluer
Q01 Adhérence, **3**	L'activité est l'hébergement d'applications (P01), les clients reviennent au papier en cas de panne (P04)	Sans SI, l'entreprise n'a plus rien à vendre	Le SI est « vital à l'accomplissement des missions »	Rien de plausible, c'est la note la plus solide
Q02 Impacts internes, **2**	Fortes pertes contractuelles, départ de certains clients, poursuite de prestations manuelles (P04)	Les conséquences sont graves mais la DG ne décrit pas une faillite	Les mots « graves » et non « fatales » collent à P04	Une étude financière montrant qu'une semaine d'arrêt menace la survie ferait passer à 3
Q03 Impacts externes, **3**	Erreurs d'orientation et de prise en charge de patients possibles (P05)	La sécurité de personnes chez des tiers est en jeu	La méthode précise que l'implication de tiers élève le niveau	Une analyse montrant des contrôles cliniques qui détectent toute erreur pourrait justifier 2. La somme ne changerait pas car Q01 vaut 3
Q04 Disponibilité, **2**	Une journée d'arrêt est grave, l'arrêt prolongé affecte la continuité des soins (P04, P05)	Grave pour l'activité, sans être présenté comme fatal	La notice met en garde contre le 3 donné parce que le SI est « important »	Un contrat avec pénalités mettant l'entreprise en péril
Q05 Intégrité, **2**	Altération non détectée, erreurs de prise en charge (P05)	L'impact est grave pour l'activité	Aucune pièce ne décrit l'altération comme fatale pour l'entreprise. Note cohérente avec Q02 et Q04	Raisonner sur la sécurité des patients plutôt que sur l'activité justifierait 3, sans effet sur la somme car Q06 vaut 3
Q06 Confidentialité, **3**	Données de santé, risque « critique » selon la DSI, attaquants visant la revente (P05, P07)	La divulgation serait fatale à la relation client	Le mot « critique » de la DSI et la nature des données	Avec 2, la somme passerait à 9 et le niveau resterait 4

Question	Ce que montre la pièce	Notre interprétation	Pourquoi cette note	Ce qui la ferait évoluer
Q07 Fréquence, **2**	10 événements en 12 mois (P06)	10/4 = 2,5 par trimestre	« Plusieurs sinistres par trimestre »	Le registre n'étant pas exhaustif, un recensement complet pourrait mener à 3
Q08 Motivation, **2**	Menaces « potentiellement fortement motivées » (P07)	Reprise presque littérale du texte	« La motivation peut être forte »	Une menace ciblée avérée contre l'entreprise ferait passer à 3
Q09 Moyens, **2**	P07 exclut seulement les moyens illimités	Le dossier ne dit rien de plus	Hypothèse d'auditeur, notée « incertain »	Sans effet sur le calcul, Q07 et Q08 fixant déjà le maximum à 2
Q10 Hétéro-généité, **2**	« Fortement hétérogène mais non extrêmement » (P08)	Reprise littérale	« Fortement hétérogène »	Aucune, la pièce tranche
Q11 Ouverture, **2**	Portail sur Internet, interconnexions sous contrat (P03, P07)	Ouvert à des internautes non maîtrisés, mais par une publication unique filtrée, et à des clients sous contrat	« Ouvert à des systèmes externes sous contrôle »	Si les contrôles contractuels sont inopérants, 3, et la somme passe à 11, soit le niveau 5
Q12 Variabilité, **2**	Changements mensuels et trimestriels, deux pannes dues aux changements (P06, P08)	Le SI bouge régulièrement	« Change relativement souvent »	Un gel des évolutions ferait baisser la note

3.2 Le calcul pas à pas

On prend le maximum de chaque famille. Pour les conséquences, $\max(3, 2, 3) = 3$. Pour la sensibilité, $\max(2, 2, 3) = 3$. Pour les menaces, $\max(2, 2, 2) = 2$. Pour les vulnérabilités, $\max(2, 2, 2) = 2$. La somme vaut $3 + 3 + 2 + 2 = 10$, qui tombe dans la tranche de 9 à 10, d'où le niveau 4. Sans ajustement, la cible est 4.

Dans l'Excel, la cellule B16 contient la formule suivante.

```
=SI(NB(C2:C4)<3;"";MAX(C2:C4))
```

Elle reste vide tant que les trois notes ne sont pas saisies, puis affiche le maximum. B17 à B19 font de même pour les autres familles. B20 additionne les quatre maxima. B21 applique le barème par une suite de SI imbriqués, qui teste d'abord si la somme est au plus 2, puis au plus 5, au plus 8, au plus 10, et renvoie 5 sinon. B22 reçoit l'ajustement, que nous laissons à 0. B23 calcule `MAX(1;MIN(5;B21+B22))`, ce qui borne la cible entre 1 et 5 quel que soit l'ajustement.

3.3 Pourquoi ce résultat est robuste

Un bon réflexe à l'oral consiste à montrer que la conclusion ne dépend pas d'une seule note contestable. Si l'on baisse Q06 à 2, la somme devient 9 et le niveau reste 4. Si l'on baisse Q03 à 2, rien ne change car Q01 vaut déjà 3. Pour tomber au niveau 3, il faudrait une somme de 8, par exemple en ramenant à 2 à la fois les conséquences et la sensibilité, ce que les pièces ne soutiennent pas. À l'inverse, la seule note qui ferait monter la cible à 5 est Q11 à 3, et nous expliquons pourquoi nous ne la retenons pas.

3.4 L'ajustement

La méthode laisse l'autorité responsable ajuster la cible d'un niveau, à condition de le justifier. La notice demande de l'inscrire en B22 et de l'expliquer dans le rapport. Deux arguments s'opposent. Pour baisser à 3, on peut invoquer la taille de l'entreprise et un RSSI à mi-temps (P02). Contre, il y a des données de santé et la sécurité de patients, et la méthode avertit qu'une cible réduite expose à une gestion inadaptée aux enjeux. Nous gardons 0 et nous traitons la contrainte de moyens par la trajectoire, qui vise d'abord le niveau 2 partout. Ce choix est défendable mais discutable, et nous précisons que la décision revient à la DG, pas aux auditeurs.

4 G3, établir la maturité effective

4.1 La grille des exigences

La méthode fournit un tableau croisant les exigences et les sept processus. Nous l'avons rempli à partir des pièces. Le symbole **O** signifie démontré, **N** non établi, **?** indéterminé faute de preuve, et **O*** déduit des pièces mais à confirmer. Un niveau n'est atteint que si toute sa colonne est démontrée jusqu'à lui. Deux critères sont appliqués de la même façon à tous les processus. Un compte rendu écrit des résultats vaut mesure qualitative, un compte rendu oral sans trace ne la vaut pas. La compétence est retenue lorsqu'un rôle chargé de la sécurité est désigné, ce qui reste à confirmer en entretien et explique le symbole **O*** de la conception.

Exigence	Stratégie	Risques	Règles	Supervision	Conception	Réalisation	Exploitation
Niveau 1							
Actions avec des pratiques de base	O	O	O	O	O	O	O
Niveau 2							
Actions planifiées	O	N	O	N	O	?	O
Acteurs compétents en SSI	O	O	O	O	O*	O	O
Certaines pratiques formalisées	O	N	O	N	O	O	O
Mesures qualitatives	?	N	O	N	O	O	O
Autorités informées	O	?	O	N	O	O	O
Niveau 3							
Processus défini, standardisé, formalisé	N	N	N	N	N	N	N
Compétences appropriées au processus	?	?	?	?	?	?	?
L'organisme soutient le processus	?	?	?	?	?	?	?
Niveau effectif démontré	**1**	**1**	**2**	**1**	**2**	**1**	**2**

Le niveau 3 est bloqué partout par la première exigence. Chaque pièce P09 à P15 signale, sous une forme ou une autre, l'absence de processus commun. P09, P11, P13, P14 et P15 le disent directement, P10 évoque l'absence de méthode stable réutilisable et P12 l'absence de procédure commune. Inutile donc de discuter les deux autres exigences du niveau 3. Aucun processus n'est à 0, car chacun montre au moins quelques actions de base.

4.2 Chaque niveau expliqué

Définir la stratégie SSI, niveau 1. P09 montre une note d'orientation approuvée par la DG, des priorités annuelles et un référent, ce qui couvre la planification et la formalisation. Le RSSI rend compte oralement deux fois par an, ce qui informe la direction. En revanche aucune mesure qualitative n'est mentionnée et le compte rendu ne laisse aucune trace écrite. Nous retenons donc le niveau 1 et classons le niveau 2 comme indéterminé, et non comme non atteint, parce que l'absence de preuve n'est pas la preuve d'une absence. Un compte rendu écrit avec quelques indicateurs simples suffirait à faire passer ce processus au niveau 2. C'est le choix le plus discutable de G3, et un correcteur pourrait accepter le niveau 2 en considérant le compte rendu oral comme une mesure qualitative.

Gérer les risques SSI, niveau 1. P10 décrit des risques recensés au fil de projets récents. Il n'y a ni calendrier de revue, ni méthode réutilisable, ni registre consolidé. Deux exigences du niveau 2 manquent clairement, la planification et la formalisation. L'analyse d'un prestataire en 2025 ne change rien, car une action isolée n'est pas une pratique répétable.

Gérer les règles SSI, niveau 2. P11 montre une PSSI approuvée, des règles écrites, une application planifiée, des contrôles qualitatifs consignés et l'information des managers. Les cinq exigences du niveau 2 sont couvertes. P17 fragilise ce niveau, car la revue annuelle prévue n'a pas de procès-verbal depuis deux ans. Nous le signalons comme réserve sans retirer le niveau, puisque la règle existe et s'applique.

Superviser la SSI, niveau 1. P12 décrit des outils et des alertes actifs, ce qui suffit au niveau 1. Mais il n'y a ni campagne de contrôle planifiée, ni reporting régulier, ni procédure commune. T08 illustre ce manque, l'alerte

AL-1048 s'étant fermée seule. Attention au raisonnement, ce n'est pas l'alerte qui fixe le niveau 1, ce sont les exigences manquantes décrites en P12. L'alerte sert de corroboration.

Concevoir les mesures SSI, niveau 2. P13 montre une fiche type, un responsable technique désigné, des revues planifiées pour les projets majeurs avec un compte rendu écrit remonté au responsable. Selon nos deux critères, ce compte rendu vaut mesure qualitative et la désignation du responsable vaut compétence. Le niveau 2 est donc retenu. Un correcteur plus strict pourrait exiger une preuve explicite de compétence, et le niveau tomberait à 1. La démarche n'est pas globale, d'où l'absence du niveau 3.

Réaliser les mesures SSI, niveau 1. P14 montre des techniciens compétents, des comptes rendus d'installation et de validation, un suivi régulier et l'information de la DSI. Quatre exigences du niveau 2 sont donc couvertes. La pièce ne dit pas « planifié », elle dit que les déploiements sont « souvent préparés ». Une préparation fréquente n'est pas une planification démontrée. Nous retenons donc le niveau 1 et classons le niveau 2 comme indéterminé, exactement comme pour la stratégie. Un échantillon de plans de déploiement datés suffirait à le débloquer.

Exploiter les mesures SSI, niveau 2. P15 couvre toutes les exigences du niveau 2 pour les sauvegardes. Les pièces T montrent pourtant des failles dans l'exploitation, avec 2 PV de restauration sur 9, 60 % de MFA et des correctifs en retard. Le dossier interdit d'attribuer un niveau entier à partir d'un seul constat technique. Nous gardons donc 2 avec la mention « fragile » et nous utilisons ces constats pour bâtir le plan d'action.

4.3 Revendiqué, démontré, indéterminé

Le sujet demande de présenter séparément ces trois notions. Le niveau revendiqué est celui que l'organisme annonce. Aucune pièce n'annonce de niveau chiffré, d'où la mention « Non déclaré » dans la colonne B de l'onglet 02, comme le prévoit la notice. Les affirmations de P17 portent sur des pratiques, pas sur des niveaux, mais elles montrent que l'organisme se perçoit plus mature qu'il ne le prouve. Le niveau démontré est celui de la colonne C. Le niveau indéterminé correspond aux exigences marquées **?**, en particulier le niveau 2 de la stratégie et celui de la réalisation.

La colonne F de l'onglet 02 calcule automatiquement l'écart `MAX(0; cible - niveau)`. Avec une cible de 4, on obtient 3 pour les processus au niveau 1 et 2 pour ceux au niveau 2. La notice rappelle que cet écart n'est pas une mesure de risque. Il dit combien de marches il reste à gravir, pas l'urgence de le faire. Une cellule C vide signifierait « non positionné faute de preuve », ce qui est différent de 0. Nous n'avons laissé aucune cellule vide car le niveau 1 est démontré partout.

5 T1 à T5, l'audit technique

5.1 T1, lire une matrice de flux

On commence par dessiner les zones et les flux à partir de T01 et T02, ce que fait la figure du rapport. On qualifie ensuite chaque règle. Une règle est douteuse lorsqu'elle est plus large que le besoin, qu'elle n'a pas de justification ou qu'elle contourne un contrôle. FW-31 cumule les trois défauts, car elle autorise tout trafic des postes vers les sauvegardes sans justification. FW-17 contourne le bastion. FW-19 est large et FW-08 n'est pas vérifiée. FW-23 autorise tout le VLAN 20 vers DB01 alors que T01 place DB01 dans ce même VLAN, ce qui demande de vérifier l'emplacement réel de la base. La règle d'or du sujet est de ne jamais conclure qu'un port ouvert est une faille exploitée. Le scan de WEB01, réalisé depuis la DMZ et non depuis Internet, montre 80 et 443 ouverts, ce qui est normal pour un portail et ne prouve aucune attaque. La vue depuis Internet se déduit des règles et devra être confirmée par un scan externe. Les contrôles complémentaires proposés visent tous à obtenir une preuve, comme des journaux de trafic, une date d'expiration ou un test de segmentation.

5.2 T2, calculer la couverture MFA

Le calcul de base est $6/10 = 60\,\%$ sur le périmètre de l'export. Deux variantes aident à raisonner. Si svc-backup est réellement non interactif, la MFA ne s'y applique pas de la même façon et la couverture des comptes interactifs devient $6/9 \approx 66{,}7\,\%$. Si l'investigation conduit à désactiver admin-old, on obtient $6/8 = 75\,\%$. Il

faut donc encore traiter admin-presta et admin-db pour atteindre 100 %. Ces variantes ne remplacent pas le chiffre officiel de 60 %, elles montrent le chemin pour le corriger. La comparaison avec P03 confirme le chiffre et la comparaison avec P17 révèle une affirmation inexacte de la DSI. Attention au vocabulaire, T04 parle de comptes enrôlés. Sans la politique d'accès conditionnel, on ne sait pas si le second facteur est réellement imposé. Le sujet demande des preuves de clôture, et la plus forte est un export exhaustif refait après correction, accompagné des exceptions signées.

5.3 T3, passer du CVSS au risque

Le score CVSS est une donnée de travail, pas un classement. Pour prioriser, nous croisons quatre éléments, le score, l'exposition, la criticité métier et l'existence de mesures compensatoires. APP01 a le score le plus élevé, 9,8, une criticité critique et un hôte en retard de correctifs de 74 jours. T06 donne ce retard par hôte, la date du correctif critique lui-même n'étant pas fournie. Il n'est pas exposé directement mais reste joignable depuis WEB01 et par la règle RDP FW-17. Il passe donc en priorité 1. WEB01 est exposé à Internet mais son constat, TLS 1.0, est peu grave si la redirection vers HTTPS fonctionne, d'où une priorité modérée. On voit qu'un actif exposé n'est pas forcément prioritaire et qu'un actif interne peut l'être. Pour AD01, l'agent indique 0 jour de retard, mais l'inventaire date du 25 septembre, soit 17 jours avant la date de contrôle du 12 octobre. Nous demandons donc un inventaire récent plutôt que de conclure.

5.4 T4, bâtir une chronologie neutre

Une chronologie neutre liste ce qui est écrit dans les journaux, dans l'ordre, sans adjectif. Les écarts de temps se calculent simplement. Entre le premier échec à 00:13:01 et le succès à 00:13:12, il s'écoule 11 secondes. Entre le succès et le changement de groupe à 00:18:32, il y a 5 minutes et 20 secondes. L'alerte arrive 3 minutes et 43 secondes plus tard, à 00:22:15, puis se ferme seule 24 heures après. Ces faits sont compatibles avec deux histoires, un attaquant qui devine un mot de passe puis s'octroie des droits, ou un administrateur d'astreinte qui se trompe de mot de passe puis fait une opération légitime. Rien dans le dossier ne permet de trancher, d'où la formule « signaux compatibles avec un événement à investiguer ». Un détail renforce le doute. Les dates de T03 vont jusqu'au 11 octobre, donc l'export est postérieur au 9, et pourtant admin-old y figure avec une dernière activité au 14 février 2025. Soit l'export ignore les connexions VPN, soit il y a une anomalie à comprendre.

Pour les sauvegardes, le calcul est $2/9 \approx 22\,\%$ de services avec un PV de test. La DG affirme que tout est testé chaque trimestre. Le rapport ne dit pas qu'elle ment, il dit que l'affirmation n'est pas démontrée et que l'absence de PV ne prouve pas l'absence de test. Les critères mesurables proposés sont des cibles à faire valider, par exemple un PV par an pour chaque service et un PV trimestriel avec durée mesurée inférieure à 8 heures pour les quatre services critiques.

5.5 T5, corréler sans tricher

La matrice relie un constat technique à un processus DCSSI. Le sujet précise qu'une affectation de niveau sans examen des exigences cumulatives n'est pas recevable. Dans la colonne « niveau », nous reprenons donc le niveau établi en G3, éventuellement qualifié de « fragile », et non un niveau déduit du seul constat. Par exemple, C04 (AL-1048) est rattaché à la supervision, dont le niveau 1 vient des exigences manquantes de P12, et l'alerte ne fait que l'illustrer. Les onze constats sont dans l'onglet 03 et six sont détaillés dans la matrice du rapport, au-delà du minimum de cinq.

6 G4, risques, budget et feuille de route

6.1 Coter un risque

La notice propose une grille simple de 1 à 4 pour l'impact et pour la vraisemblance, puis un score égal à leur produit, de 1 à 16. L'impact se justifie par le métier, ici les données de santé, la sécurité des patients et le RTO contractuel. La vraisemblance se justifie par l'exposition, la menace décrite dans P07 et les mesures existantes. Pour R01, l'impact vaut 4 car un administrateur de domaine peut tout modifier, et la vraisemblance vaut 3

car 4 comptes sur 10 n'ont pas de MFA, l'accès VPN est exposé et des signaux suspects existent déjà. On obtient $4 \times 3 = 12$. Pour R03, l'impact vaut aussi 4 mais la vraisemblance tombe à 2 car APP01 n'est pas exposé directement, soit $4 \times 2 = 8$.

La notice insiste sur un point utile à l'oral. Deux scores égaux n'appellent pas le même traitement. R04 et R06 valent tous deux 9, mais R04 se réduit par des réglages techniques peu coûteux alors que R06 dépend d'une standardisation lourde des projets. De même, un risque 4×2 et un risque 2×4 valent 8, mais le premier est rare et grave, le second fréquent et modéré.

Chaque risque reçoit une décision parmi quatre possibles. Réduire signifie investir pour baisser l'impact ou la vraisemblance. Éviter signifie renoncer à l'activité risquée. Transférer ou partager signifie confier une partie du risque à un tiers, assureur ou prestataire. Accepter signifie vivre avec le risque en connaissance de cause, avec un décideur identifié. Nous avons réduit R01 à R05 et accepté temporairement R06, en nommant la DG ou la DO comme décideur.

6.2 L'arbitrage budgétaire, étape par étape

Le plafond est de 120 000 €. Les montants viennent de P16 et de T10, et deux pièges sont signalés par le dossier. Le lot de restauration à 22 000 € apparaît dans P16 et dans T10 mais c'est la même prestation, à ne compter qu'une fois. L'outillage quantitatif de P16 et la détection de T10, à 35 000 € chacun, sont des alternatives sans équivalence garantie, et il faut expliquer son choix.

Notre raisonnement suit l'ordre des risques. On retient d'abord A08 (MFA, 28 000 €) et A05 (restauration, 22 000 €) pour R01 et R02, soit 50 000 €. On ajoute A01 (registre des risques, 18 000 €) et A02 (supervision, 16 000 €), qui font progresser les deux processus au niveau 1 et traitent l'absence d'examen tracé de l'alerte, soit 84 000 € au total. On ajoute A09 (correctifs, 18 000 €) pour R03, ce qui porte le total à 102 000 €. Il reste 18 000 €. La segmentation A10 coûte 30 000 € et dépasserait le plafond. A03 (PSSI et sensibilisation, 14 000 €) tient dans l'enveloppe et répond à l'hameçonnage, qui représente la moitié des événements de P06, ainsi qu'à la revue de PSSI sans PV. Le total atteint 116 000 €, avec une marge de 4 000 €.

Dans l'Excel, la cellule C16 contient la formule `=SOMMEPROD(D2:D12;G2:G12)`, qui multiplie chaque coût par 1 ou 0 selon la colonne G puis additionne, ce qui revient à additionner les coûts des actions retenues. C17 calcule la marge, plafond moins total, et C18 affiche « BUDGET RESPECTÉ » si le total ne dépasse pas le plafond. Le calcul se vérifie à la main, $18 + 16 + 14 + 22 + 28 + 18 = 116$ milliers d'euros.

Choix discutable. On pourrait préférer A10, la segmentation, à A02 et A03 réunis, qui coûtent ensemble 30 000 €. C'est l'exemple de calcul donné dans la notice. Nous ne l'avons pas retenu car la supervision est au niveau 1, que la méthode conseille de faire progresser d'abord les processus les plus faibles, et que les deux règles les plus dangereuses, FW-31 et FW-17, peuvent être restreintes en régie sans attendre le projet complet. Ce dernier point est une hypothèse à confirmer avec la DSI.

Les mesures différées sont A04, A06, A07, A10 et A11. Chacune laisse un risque résiduel qu'il faut nommer. Le report de A10 laisse R04 et une partie de R02, le report de A04 laisse R06. Le report de A11 limite la détection outillée sur R01, compensée en partie par A02. Le report de A06 prive le pilotage d'indicateurs chiffrés, celui de A07 expose à une adhésion insuffisante aux nouvelles pratiques. Ces risques doivent être acceptés par écrit par la direction, ce qui transforme un manque de budget en décision assumée.

6.3 Les preuves de clôture

Une action n'est terminée que si l'on peut le prouver. Pour chaque constat, la colonne I de l'onglet 03 indique la pièce future qui le démontrera. Par exemple, la clôture de C01 exige un export MFA exhaustif à 100 % ou des exceptions signées, et celle de C05 des PV de restauration datés avec une durée mesurée pour chaque service. Ces preuves servent aussi à valider les paliers de maturité. Un processus ne passera au niveau 2 que lorsque les preuves correspondantes existeront.

6.4 La trajectoire sur douze mois

La méthode recommande de progresser d'un niveau à la fois en commençant par les processus les plus faibles. Les six premiers mois portent donc la stratégie, les risques, la supervision et la réalisation au niveau 2, ce qui aligne les sept processus. L'étape de la stratégie est rattachée à A01 et celle de la réalisation à un plan de déploiement établi en régie. Le second semestre stabilise et prépare, sans l'atteindre, le niveau 3 des règles et de l'exploitation, qui exige une standardisation commune à tout l'organisme. Les mesures conservatoires sur AL-1048, FW-31 et FW-17 ne suivent pas ce calendrier et sont à engager dès la remise du rapport. La cible 4 reste un objectif à moyen terme. Il ne faut pas confondre cette feuille de route, qui concerne MEDICA-SERVICES, avec le calendrier de production du projet étudiant, qui court du 20 octobre au 10 novembre 2026.

7 La grille Excel, onglet par onglet

L'onglet 01 reçoit les douze notes en C, les pièces en D, la justification en E et la confiance en F. Les listes de validation limitent les notes à 0, 1, 2 ou 3 et la confiance à cinq valeurs. Les formules B16 à B23 ne sont pas touchées, seul B22 reçoit l'ajustement.

L'onglet 02 reçoit en B la mention « Non déclaré », en C le niveau démontré, en D les preuves, en E les exigences manquantes et en G l'action de progression. La colonne F calcule l'écart à partir de la cible de l'onglet 01.

L'onglet 03 contient onze constats. Les cinq premiers étaient préamorcés et ont été complétés, les six suivants ajoutés. Chaque ligne sépare l'observation (colonne C) de la qualification (colonne D) et prévoit une preuve de clôture (colonne I).

L'onglet 04 contient six risques. Les colonnes G et H acceptent les valeurs 1 à 4 et la colonne I calcule le score. Les lignes R07 à R10 restent vides et leur formule affiche une cellule vide.

L'onglet 05 conserve les coûts préremplis, vérifiés un par un. Les colonnes E, F, G et H sont complétées et la colonne G vaut 1 pour les six actions retenues.

L'onglet 06 est laissé vierge, car il est réservé à l'enseignant. Ses formules affichent 0 tant que la colonne D n'est pas remplie.

Les valeurs du rapport et de l'Excel ont été contrôlées pour être identiques, et la grille a été recalculée pour vérifier qu'aucune formule ne renvoie d'erreur.

8 L'organisation du projet

Le Gantt montre les fenêtres de travail de chaque membre, les dépendances et quatre jalons. Les barres ne signifient pas un travail à plein temps, mais la période pendant laquelle la tâche doit avancer. Le Kanban reprend exactement les mêmes identifiants E1 à E18. Le Gantt décrit le planning cible, le Kanban décrit l'avancement attesté. Comme aucun avancement n'a été documenté, le Kanban montre son état initial du 20 octobre, toutes les cartes étant dans « À faire ». L'équipe déplace ensuite chaque carte au fil des preuves de réalisation. Les dépendances sont de type début-début. Une tâche aval démarre après le début de la tâche dont elle dépend et se termine après elle, ce qui explique les chevauchements, par exemple la rédaction qui commence avant la fin de la corrélation.

ID	Tâche	Pilote	Fenêtre	Dépend de	Kanban	État attesté
E1	Lecture du sujet et des pièces	Tous	20/10 au 22/10	·	À faire (initial)	à renseigner
E2	Collecte des preuves P/T	Team	21/10 au 24/10	E1	À faire (initial)	à renseigner
E3	G1 Périmètre et limites	Team	23/10 au 27/10	E2	À faire (initial)	à renseigner
E4	G2 Autodiagnostic Q01 à Q12	Marc	23/10 au 28/10	E2	À faire (initial)	à renseigner

ID	Tâche	Pilote	Fenêtre	Dépend de	Kanban	État attesté
E5	T1 Architecture et flux	Matteo	23/10 au 28/10	E2	À faire (initial)	à renseigner
E6	T2 Identités et MFA	Matteo	26/10 au 29/10	E2	À faire (initial)	à renseigner
E7	T3 Vulnérabilités	Bernard	26/10 au 30/10	E2	À faire (initial)	à renseigner
E8	T4 Journaux et sauvegardes	Bernard	27/10 au 31/10	E2	À faire (initial)	à renseigner
E9	Atelier de consolidation	Tous	29/10 au 29/10	E4, E6	À faire (initial)	à renseigner
E10	G3 Sept processus	Marc	29/10 au 02/11	E4, E9	À faire (initial)	à renseigner
E11	T5 Corrélation	Matteo	30/10 au 03/11	E5, E6, E7, E8	À faire (initial)	à renseigner
E12	G4 Risques, budget, feuille de route	Team	31/10 au 04/11	E10, E11	À faire (initial)	à renseigner
E13	Remplissage progressif de l'Excel	Bernard	23/10 au 05/11	E2	À faire (initial)	à renseigner
E14	Rédaction du rapport	Team	02/11 au 06/11	E10, E11	À faire (initial)	à renseigner
E15	Relectures croisées	Tous	05/11 au 07/11	E14	À faire (initial)	à renseigner
E16	Corrections	Marc	06/11 au 08/11	E15	À faire (initial)	à renseigner
E17	Compilation et contrôle du PDF	Team	07/11 au 08/11	E16	À faire (initial)	à renseigner
E18	Présentation CODIR et répétition	Matteo	06/11 au 09/11	E12	À faire (initial)	à renseigner

9 Hypothèses et choix discutables

Choix retenu	Alternative défendable	Effet sur les résultats
Q05 à 2	Q05 à 3 si l'on raisonne sur la sécurité des patients	Aucun, Q06 maintient la sensibilité à 3
Q09 à 2	Q09 à 1, faute d'information sur les moyens	Aucun, le maximum des menaces reste 2
Q11 à 2	Q11 à 3 si l'on juge Internet hors de contrôle	La somme passe à 11 et la cible à 5
Ajustement à 0	Ajustement de −1 au vu de la taille de l'entreprise	Cible 3, écarts réduits d'un niveau
Stratégie au niveau 1	Niveau 2 si le compte rendu oral vaut mesure qualitative	Écart de 2 au lieu de 3
Réalisation au niveau 1	Niveau 2 si l'on admet que « souvent préparés » vaut planification	Écart de 2 au lieu de 3
Conception au niveau 2	Niveau 1 si la compétence doit être prouvée explicitement	Écart de 3 au lieu de 2
Exploitation au niveau 2 « fragile »	Niveau 1 si l'on considère que les constats T annulent le niveau	Contraire à la règle du dossier sur les constats isolés
Cotations des risques	Autres valeurs selon l'appréciation de l'impact	Ordre de priorité possiblement modifié, sans changer R01 et R02 en tête
A02 et A03 plutôt que A10	A10 retenue à la place	Même total de 116 000 €, supervision non traitée
Restriction de FW-31 et FW-17 en régie	Pas de capacité interne	Ces règles attendraient l'année 2

Choix retenu	Alternative défendable	Effet sur les résultats
Mesures du critère de restauration	Autres seuils fixés par la DG	Critères de vérification différents

10 Préparer l'oral

Les questions suivantes sont probables lors de la soutenance. Les éléments de réponse s'appuient sur les pièces et doivent être reformulés avec tes mots.

Question possible	Éléments de réponse
L'entreprise est-elle au niveau 4 ?	Non. Le niveau 4 est sa cible, calculée à partir des enjeux. Ses processus démontrent 1 ou 2.
Pourquoi pas une intrusion confirmée le 9 octobre ?	Les journaux ne sont pas certifiés, il n'y a ni trace MFA ni entretien avec le titulaire, et une opération légitime reste possible. Nous prescrivons une investigation et des mesures conservatoires.
Pourquoi APP01 avant WEB01 alors que WEB01 est exposé ?	Le CVSS ne suffit pas. APP01 est critique, très en retard, joignable depuis la DMZ et par RDP. Le constat de WEB01 est moins grave si la redirection fonctionne.
Pourquoi ne pas retenir la segmentation ?	Le plafond ne le permet pas sans sacrifier la supervision, au niveau 1. Les deux règles dangereuses sont restreintes en régie et le risque résiduel est accepté par la DG.
Pourquoi la stratégie au niveau 1 ?	Toutes les exigences du niveau 2 doivent être démontrées. Aucune mesure qualitative n'est documentée et le compte rendu est oral. Le niveau 2 est indéterminé, pas exclu.
Pourquoi ne pas mettre l'exploitation à 1 vu les constats ?	Le dossier interdit d'attribuer un niveau entier à partir d'un constat isolé. Les exigences du niveau 2 sont couvertes par P15. Nous qualifions le niveau de fragile.
Que vaut la déclaration de la DG sur les tests trimestriels ?	Elle n'est pas démontrée, 2 PV sur 9. L'absence de PV ne prouve pas l'absence de test, d'où la demande des PV manquants.
Que reste-t-il après le plan ?	R04 et R06, et une part de R02 liée au cloisonnement. Ils sont acceptés pour 12 mois et réexaminés au bilan annuel.
Pourquoi la méthode de 2007 ?	Elle est demandée par le TD comme référence pédagogique historique. Elle ne vaut pas certification ni conformité actuelle.

Source méthodologique : SGDN/DCSSI, Maturité SSI, approche méthodologique, 2 novembre 2007, consultée sur le site de l'ANSSI (cyber.gouv.fr). MEDICA-SERVICES et l'ensemble des pièces sont fictifs.